Abertay University

Dynamic Web Development - Report

Zack Anderson – [e-mail removed]

Dynamic Web Development CMP 204

BSc Ethical Hacking Year 2

Abstract

The aim of this project was to create an aesthetically pleasing website that was also functional, easy to use for all types of users, with purposeful interactive elements which enhance the user experience. The website must also be usable on various screen sizes, aspect ratios, and resolutions.

The use of this Website is to provide some information to users, who would most likely be tourists, on the town of St Andrews, its heritage, and attractions. Every element of each webpage uses bootstrap to make viewing on all devices from desktop to mobile attractive and functional. JavaScript, AJAX, jQuery and PHP were all used to add functionality and improve the user experience on the website.

Contents

1 Introduction 5
1.1 Web Standards 5
1.2 Browser Compatibility 5
1.3 Bootstrap 6
1.4 Design 6
1.5 AJAX 7
2 Legal Implications 8
2.1 Image Copyright 8
2.2 Cookies & Cookie Law 8
2.3 Data Protection Act 1998 9
3 Index.php 10
3.1 simpleWeather.js 10
3.2 Navigation Bar 10
4 Landmarks.php 11
4.1 Image grid and overlays 11
4.2 Modals 11
5 News.php 12
5.1 AJAX and jQuery manipulating the DOM 12
6 Login.php & Admin.php 13
6.1 Log In form 13
6.2 Adding, Editing and removing information from a table 13
7 Security 14
7.1 Password Hashing 14
7.2 Cross-site scripting & SQL Injection 14
8 Conclusion 15
8.1 Future Work 15
Appendices 16
Appendix A 16
Appendix B 17
References 17

1 INTRODUCTION

1.1 WEB STANDARDS

Web standards are used to ensure that websites are available across a multitude of devices in a variety of places. W3C has a variety of documents on web standards which specify privacy, mobile web, and web accessibility standards.

- Privacy standards include Do Not Track standardisation (which is currently unfinished), and the Platform for Privacy Preferences Project (P3P) which allows websites to tell a user agent the privacy practices of the website. This would automate the privacy policy which users are currently required to accept (though rarely read) when accessing a website.
- Mobile web standards were developed to optimise the user experience of both desktop & mobile visitors to a website. Websites designed for use on mobile must be mindful of network costs and bandwidth, memory and CPU limitations, and keyboard and pointing devices differences. Technologies designed to compensate for these changes are CCS Mobile, SVG Tiny, and XHTML for mobile. W3C state that there are many similarities between the challenges faced by mobile users and those faced by users with disabilities, resulting in the documents for “Web Accessibility Guidelines” and “Mobile Web Best Practices” sharing several similarities.
- Web Accessibility standards, as defined by W3C, include practices such as including alternative text – also known as “alt” – tags for any images to give a text description of the image contents for vision-impaired users, allowing all features of the website to be used without the input of a pointer, and use of images and contrasting colours between texts and backgrounds to allow users with visual impairments to use the website. These are crucial to allowing the web application to be available to a wide user base.

1.2 BROWSER COMPATIBILITY

Browser compatibility is the capability of a website to adapt to working in various browser environments in many Operating System environments. These are important as users will be visiting the website in several combinations of software and hardware environments, and if the website is unreadable or dysfunctional in any of these, then users will not visit the site.

As the website was designed following web standards, it should be compatible with all browsers, however, has only been tested in Chrome, Chrome mobile and Edge. All pages on the site were also run through the “Validity” HTML Validator plugin for Chrome.

1.3 BOOTSTRAP

Bootstrap is a development framework for HTML, CSS, and JavaScript which makes it faster and easier to make a responsive web page, built by a team of developers from Twitter. It provides a mobile-first design structure and then adapting the website to fit larger screen sizes, known as “Progressive Enhancement”. This means that the website has wider compatibility, higher reliability across multiple screen sizes, and several performance benefits, as well as allowing the website to maintain functionality & aesthetics.

It also makes developing a web page much easier with many design templates for objects such as navigation bars, modals, forms, which are very useful and easy to use. All objects in a Bootstrap page are placed within “containers” which are built of 12 columns. Each object can be assigned to take up a set number of columns in the page, which bootstrap then responsively re-sizes depending on the screen size of the device.

1.4 DESIGN

The main page of the website is designed to advertise the town, with a large banner picture looking over the town and a small paragraph about the heritage of the town. The design of the page is consistent across the whole website, with design and contrasting colours chosen to make the website easier to read and use. All aspects of the page dynamically re-size depending on the users’ device. To optimise the web page for use on lower bandwidth connections, all images used were in JPEG format as these on average had a 50-75% smaller file size than PNG’s and image transparency was not necessary, however images were kept at full resolution even at smaller sizes so that the website was attractive to look at, even on high DPI displays such as phones or high-resolution computers. Each image is also assigned an “alt” tag for accessibility.

1.5 AJAX

Asynchronous JavaScript and XML (AJAX) allows web developers to refresh part of a webpage without having to re-download the whole page, making the web page more seamless, also reducing demand on network bandwidth while improving the response time compared to a regular HTTP request. It can also be used to allow some web applications to take place on a single page, eliminating the need for several HTML documents.

AJAX works by sending an XMLHttpRequest when an event happens, the web server then creates a response to send back, which JavaScript then inserts into the DOM & updates the page content (See Figure 4).

Disadvantages to AJAX include weaker security (depending on application, as all scripts are downloaded client side), it will not work if JavaScript is disabled in the users' browser, the user can only use it to access information from the host that served the initial page. If the user needs to display information from another server, it is not possible with AJAX due to security constraints. AJAX also renders the back and refresh buttons on a browser useless, so in advanced dynamic web applications, if a user presses refresh they will be taken to the base HTML page before any dynamic elements are processed and any changes will not be saved.

2 LEGAL IMPLICATIONS

2.1 IMAGE COPYRIGHT

Should the website be used online, each image would have to have its rights holder contacted to get permission to use each image, and their copyrights acknowledged. Copyright covers all creative entities and is designed to stop an artist or creators work from being misused or distributed without their permission.

2.2 COOKIES & COOKIE LAW

If a website uses cookies, under UK law it is legally obligated to notify the visitor of this & how they use them. It is also required that the website obtain the consent of the visitor to use cookies, which the user does not have to accept if they feel they are too invasive or may affect their privacy. The maximum penalty for not complying with EU cookie laws is £500,000 for cases where there is a deliberate breach of the law that causes substantial distress.

Cookies have many different uses, including counting visitors, storing basket items, personalising content and recording user preferences, auto-filling forms, targeting advertising, and for authentication and security.

The use of cookies in this website is to display a welcome message to the user the first time they visit the page and remember if they have read it, so the user is not annoyed by the message every time they load up a page in the website.

2.3 DATA PROTECTION ACT 1998

The Data Protection Act 1998 is designed to regulate how businesses, organisations, and the government use customer data. Companies are responsible for the data they store, protecting user privacy & destroying data which is no longer needed.

The Data Protection Act ensures that all data is used fairly and lawfully, for specifically stated purposes & durations, is not excessive, kept safe & secure, and is handled according to people's data protection rights.

The web application needs to abide closely by these laws when storing any data about users. All companies and businesses are also legally required to give a user a copy of all information held about them if requested by the user (information can be withheld if it is related to the prevention, detection or investigation of a crime, is a matter of national security, is related to the collection or assessment of tax, or judicial or ministerial appointments).

3 INDEX.PHP

3.1 SIMPLEWEATHER.JS

The weather plugin used on the main page of the website was made using simpleWeather.js, a simple to use though highly customisable widget made using jQuery. This provides the user who may be a tourist looking at visiting the town for a day with information on the temperature and current weather. The thumbnail images are a low resolution as the icons were off-centre in the high-resolution versions. The weather widget is also dynamic and updates every 5 minutes.

3.2 NAVIGATION BAR

The navigation bar of the website allows the user to easily navigate between pages on the website and shows the user which page they are currently on. This was made using bootstrap and therefore is designed to work on all screen sizes. Once the screen goes below a given size the navigation bar will collapse into a sub-menu which can be accessed with the “burger” option button which appears when this happens.

4 LANDMARKS.PHP

4.1 IMAGE GRID AND OVERLAYS

Each landmark in the drop-down menu in the navigation bar has its own image in the image grid on the landmarks page. Instead of having headings under each image, the images have overlays which are animated using CSS to appear when the cursor on the device is placed over the image, telling the user the name of the landmark.

4.2 MODALS

When the image overlay is clicked, a bootstrap modal is opened which shows information about the landmark, such as its address. Users can close the modal by clicking outside the box, pressing the close button, and by pressing the escape key on their keyboard (the latter is not standard behaviour in bootstrap, however, and was implemented to improve the ease of use on the website).

5 NEWS.PHP

5.1 AJAX AND JQUERY MANIPULATING THE DOM

JavaScript and AJAX were used to manipulate the DOM by editing the paragraph of each news story to an expanded version of the text from a text file on the server when a button is clicked. jQuery was also used in the script to edit the text of the button and to set the attributes of each button to allow the story to be minimised again when the button is clicked, shown in Figure 2.

6 LOGIN.PHP & ADMIN.PHP

6.1 LOG IN FORM

The only users with accounts on the website are admins (as there is no need for the public to log into the website.) Clicking the “Log In” button re-directs the user to “loginAction.php”, which checks the username and password hash against the database and then either notifies the user that their credentials are incorrect before redirecting them back to the log in page or, if the details were correct, re-directs them to “admin.php”.

The log in form uses the HTTP POST method to forward the credentials to the PHP script so that they remain hidden (see Figure 3).

6.2 ADDING, EDITING AND REMOVING INFORMATION FROM A TABLE

The admin page allows the user to add or remove accounts from the database as well as allowing the user to change the password of an account (if they know the password of that account) using PHP scripts. All accounts created have their passwords hashed using sha-512 before being stored in the database. If the user tries to access the page or any of the scripts without an active log in session, they are re-directed to the log in page using the code seen in Figure 1.

7 SECURITY

7.1 PASSWORD HASHING

Passwords are hashed using sha512 to protect user passwords in the event of unauthorised access to the database. Storing passwords in plain text is considered very bad practice as it means an attacker could simply dump passwords if they gained access to the database. Improvements on this could be using the PHP 5.5 “password_hash()” function which uses “bcrypt” to store passwords more securely, which could further be improved by salting the hashes.

7.2 CROSS-SITE SCRIPTING & SQL INJECTION

Cross-site Scripting (XSS) is an exploit found in any web application without the necessary precautions. This allows an attacker to execute client-side scripts maliciously in a legitimate web page to steal log in details or other personal information. Steps have been taken to combat against it by using the “stripslashes()” and the “mysqli_real_escape_string()” functions to remove slashes and escape special characters, meaning that code cannot be run by entering tags into text fields on the website.

Similarly, SQL injection is when an attacker enters text into a text field to be run as part of the SQL query. Since mySQLi’s query function can only execute one SQL command at a time, SQL injection is not possible on the website.

Although all necessary precautions have been taken to protect user information, the Mayar server is not configured to force HTTPS meaning if a user logged into the admin account without correcting their browser to the HTTPS version of the site, the username and password would be sent via plain text. This opens the user to a potential “man in the middle” attack whereby someone can monitor network data and steal the username & password for logging into the website.

8 CONCLUSION

In conclusion, the designed web application makes use of technologies such as Bootstrap, JavaScript, jQuery, AJAX, and PHP to deliver a functional and easy to use website with a useful implementation of features to optimise user experience while taking precautions to maintain security and user privacy.

- With the help of Bootstrap, the website has an attractive layout with a responsive, mobile-first design with good contrast between backgrounds and images to make it easy for users to read and animated elements to enhance the aesthetics of the site.
- The website log in functionality allows a user with admin credentials to add, edit or remove information from the database with a log in check for all pages that can only be accessed by admins.
- The web application uses AJAX to load text from a file on the server and then utilises JavaScript to replace the text on the page with the text from the file, and jQuery to set the attributes and text of the button.
- Cookies have been implemented to display a welcome message to the user when they first visit the site.

8.1 FUTURE WORK

- One step that could be taken to improve the website further would be to add an interface for writing and submitting news stories, as this is currently done manually. This could be done by filling out a form, saving the text and a shortened version of the text to the server and creating a database table to store the title, author, and file path of each story. Then by using a combination of AJAX and PHP, the page could be properly formatted using jQuery to display news stories to users.
- Another improvement could be to add high resolution versions of weather thumbnails for the widget to enhance the appearance of the web page on certain screen sizes.
- The landmark functionality could be improved by embedding a Google maps window to show the location of each landmark alongside the rest of the information, as well as adding a filter for types such as restaurants, landmarks, and leisure.

APPENDICES

APPENDIX A

```php
//checks if the user is logged in
if($_SESSION['LoggedIn'] != TRUE){
   //if not, send them back
  header("Location: ../login.php");
  }
```

Figure 1 – Code to check if the user has logged in. If not, they are re-directed to the log in page.

```javascript
function originalText(id, filename, btnID)
{
  var xhttp = new XMLHttpRequest();

  var newbtnID = "#" + btnID;

  var newfilename= filename + "(original).txt";     //adds the appropriate end to the filename to retrieve the original text

  xhttp.onreadystatechange = function() {
    if (this.readyState == 4 && this.status == 200) {
     document.getElementById(id).innerHTML = this.responseText;
    }
  };

  $(newbtnID).text('Expand');
  $(newbtnID).attr("onclick","loadDoc('"+id+"','"+filename+"','"+btnID+"')");

  xhttp.open("GET", newfilename, true);
  xhttp.send();
};
```

Figure 2 – Code which edits the contents of the DOM on “News.php”

```php
$usrName = $_POST['username'];
$pass = $_POST['pwd'];

$usrName = stripslashes($usrName);
$usrName = mysqli_real_escape_string($conn,$usrName); //escapes special characters
$pass = stripslashes($pass);
$pass = mysqli_real_escape_string($conn,$pass);   //escapes special characters
$pass = hash('sha512',$pass);
```

Figure 3 – Security Measures (default login credentials are “admin”, ”password”)

APPENDIX B

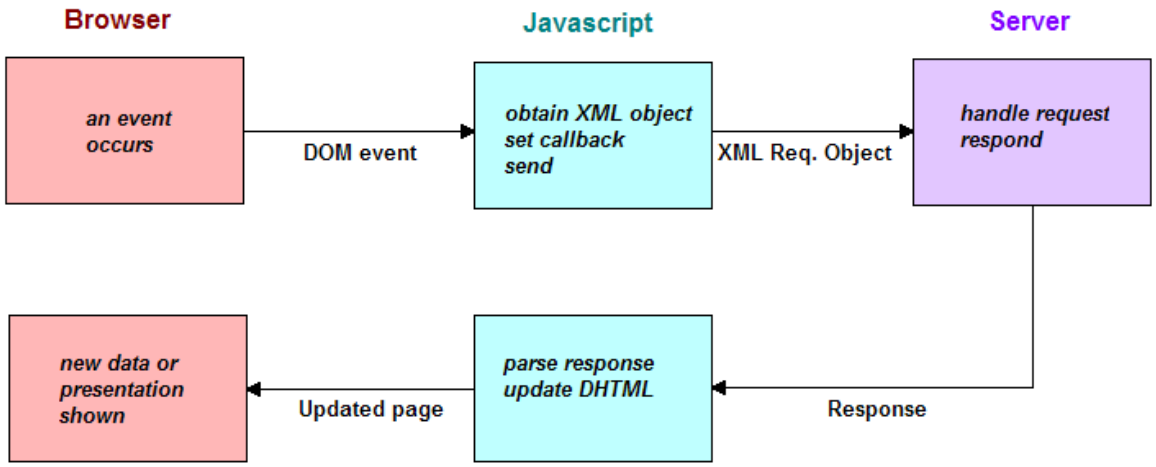

Figure 4 – How AJAX operates

REFERENCES

W3C Standards - https://www.w3.org/standards/ (accessed 22nd November 2017)

Validity Chrome extension - https://chrome.google.com/webstore/detail/validity/bbicmjjbohdfglopkidebfccilipgeif?utm_source=chrome-app-launcher-info-dialog (accessed 18th November 2017)

The Performance Benefits of Progressive Enhancement - https://blog.prototypr.io/the-performance-benefits-of-progressive-enhancement-ff324ba7c435 (accessed 10th November 2017)

Bootstrap Documentation - https://bootstrapdocs.com/v3.3.6/docs/ (accessed 10th November 2017)

AJAX Pros and Cons - http://www.jscripters.com/ajax-disadvantages-and-advantages/ (accessed 16th November 2017)

Copyright and use of photographic images on the web - https://www.exeter.ac.uk/staff/web/copyright/ (accessed 23rd November 2017)

A simple guide to cookies and how to comply with EU cookie law - https://www.wired.co.uk/article/cookies-made-simple (accessed on 23rd November 2017)

Simple Weather - http://simpleweatherjs.com/ (Accessed on 3rd November 2017)

Cross-site Scripting (XSS) Attack - https://www.acunetix.com/websitesecurity/cross-site-scripting/ (Accessed 21st November 2017)

PHP Documentation - http://www.php.net/manual/en/mysqli.quickstart.multiple-statement.php (accessed 2nd November 2017)

AJAX Introduction - https://www.w3schools.com/php/php_ajax_intro.asp (accessed 17th November 2017)